

Fundamentals of Information Systems Security

Case Study: The Equifax Data Breach (2017)

Lessons in Patch Management, Disclosure, and Security Governance

Executive Summary

The Equifax data breach of 2017 stands as one of the most consequential cybersecurity failures in American history. Between May and July 2017, attackers exploited an unpatched vulnerability in Apache Struts to access Equifax’s systems, exfiltrating sensitive personal information belonging to approximately 147.9 million Americans[reference:0][reference:1]. The breach resulted in up to \$700 million in settlements and fines, the resignation of the CEO, CIO, and CSO, and permanently damaged the company’s reputation[reference:2][reference:3]. This case study examines the causes, impact, and critical lessons learned from this watershed event in information security history.

Background: Who Is Equifax?

Equifax is one of the three major consumer credit reporting agencies in the United States, alongside Experian and TransUnion. The company collects and maintains personal financial information on hundreds of millions of consumers, including:

- Social Security numbers
- Dates of birth
- Addresses
- Credit history and payment records
- Employment information

Given the sensitivity and volume of data it holds, Equifax is a prime target for cybercriminals and operates under significant regulatory scrutiny.

The Vulnerability: Apache Struts CVE-2017-5638

The breach was caused by a failure to patch a known vulnerability in the Apache Struts web application framework, which Equifax used on its web servers[reference:4].

Key Vulnerability Details

- **Vulnerability:** CVE-2017-5638 (Apache Struts)
- **Nature:** Remote code execution vulnerability
- **Patch Released:** March 2017
- **Equifax Breach:** May - July 2017
- **Gap:** Approximately 60+ days between patch availability and exploitation

The vulnerability allowed attackers to remotely execute code on target systems without authentication. A patch was made publicly available in early March 2017, giving organizations ample time to protect themselves[reference:5].

The Breach Timeline

March 2017: Patch Released

Equifax was notified of the Apache Struts vulnerability and, according to testimony from former CEO Richard Smith, an internal email was sent on March 9th instructing that the patch be deployed within 48 hours[reference:6].

March - May 2017: Failure to Patch

Despite the directive, Equifax failed to patch all vulnerable systems. The company's vulnerability scanning tool had an expired digital certificate, preventing the security team from identifying the vulnerability[reference:7]. The responsible individual failed to communicate the patching requirement effectively[reference:8].

May - July 2017: Attackers Gain Access

Hackers began exploiting the unpatched vulnerability on March 13th, 2017, accessing Equifax's ACIS database[reference:9][reference:10]. They operated undetected for months, stealing vast amounts of personal information[reference:11].

July 29, 2017: Breach Discovered

Equifax discovered the breach when suspicious network activity was detected[reference:12].

September 7, 2017: Public Disclosure

Equifax publicly announced the breach, revealing that 143 million Americans were affected[reference:13].

What Was Stolen?

The breach exposed an unprecedented volume of sensitive consumer data[reference:14]:

Data Type	Number Affected
Names and dates of birth	147 million
Social Security numbers	145.5 million
Payment card numbers and expiration dates	209,000
Driver's license numbers	(included in affected total)

Table 1: Data Exposed in the Equifax Breach

Financial and Legal Consequences

The breach resulted in historic financial penalties[reference:15][reference:16]:

- **FTC Settlement:** \$575 million minimum, up to \$700 million[reference:17]
- **Consumer Restitution Fund:** \$425 million for affected consumers[reference:18]

- **State Settlements:** \$175 million paid to 48 states and territories[reference:19]
- **CFPB Penalty:** \$100 million[reference:20]
- **Class-Action Lawsuits:** Approximately \$1.38 billion[reference:21]

Beyond monetary penalties, Equifax was required to[reference:22]:

- Implement a comprehensive information security program
- Obtain annual certifications from its board of directors
- Undergo third-party security assessments every two years
- Provide affected consumers with 10 years of free credit monitoring and identity restoration services[reference:23]

Root Causes of the Breach

1. Failed Patch Management

The most direct cause was the failure to apply a publicly available patch[reference:24]. Equifax had a 48-hour internal SLA for patching critical vulnerabilities but could not locate all vulnerable systems[reference:25]. Former CEO Richard Smith testified that "the human error was that the individual who's responsible for communicating in the organization to apply the patch, did not"[reference:26].

2. Expired Security Certificates

Equifax had allowed a digital certificate for its vulnerability scanning tool to expire nearly a year before the breach, rendering the team unable to decrypt traffic to identify malicious behavior[reference:27].

3. Inadequate Vulnerability Management

Vulnerability scanning was treated as a quarterly PCI compliance activity rather than a continuous security practice[reference:28]. The company lacked comprehensive asset inventory and proper scan scoping[reference:29].

4. Poor Security Architecture

Credentials were stored in plain text in an unsecured file, allowing attackers to obtain administrative credentials and mask their activities[reference:30].

5. Ineffective Communication

There was a breakdown in communication between security, IT, and executive management[reference:31]. The security team could not effectively communicate the severity and urgency of the vulnerability to those who could act on it.

Lessons Learned

Lesson 1: Patch Management Requires Rapid Response

The time between a patch being issued and installed should be measured in days, not months[reference:32]. Organizations must treat all patches as potentially urgent, regardless of business disruption concerns.

Lesson 2: Vulnerability Scanning Is a Continuous Process

Scanning should not be limited to quarterly compliance checks[reference:33]. Weekly or continuous scanning ensures timely identification of new, pre-existing, or reintroduced vulnerabilities[reference:34].

Lesson 3: Maintain Comprehensive Asset Inventory

Organizations must continuously track their technology inventory to ensure proper scan scoping[reference:35]. Without knowing what systems exist, security teams cannot protect them.

Lesson 4: Use CVSS Scores Holistically

Organizations should consider base, temporal, and environmental CVSS scores when prioritizing vulnerabilities[reference:36]. The environmental score, which assesses impact on the organization's specific data and operations, is critical for informed decision-making.

Lesson 5: Implement Layered Defenses

Even during the patching gap, organizations can implement compensating controls[reference:37]. Intrusion detection rules (e.g., Snort) can be deployed to detect and block exploit attempts immediately after disclosure[reference:38].

Lesson 6: Foster a Security Culture

Security is not the responsibility of a single individual[reference:39]. Organizations must build a culture where cybersecurity is everyone's responsibility, with clear communication channels between security teams and executive leadership[reference:40].

Post-Breach Improvements at Equifax

Jamil Farshchi, who took over as CISO after the breach, implemented three key initiatives[reference:41]:

1. **Improved Systems Monitoring:** Continuous, real-time monitoring of all security controls across cloud and on-premise environments[reference:42]
2. **Enhanced Executive Communication:** Better dialogue between the security team and the C-suite
3. **Cultural Change:** Getting all employees to recognize the importance of cybersecurity

Discussion Questions

1. How could Equifax's patch management process have been improved to prevent this breach?
2. What role did leadership accountability play in this incident? Should executives be held personally responsible for security failures?
3. How does the Equifax breach demonstrate the importance of the "defense in depth" principle?
4. What are the long-term implications for consumers whose Social Security numbers were exposed?

5. How should organizations balance the need for rapid patching against the risk of patch-induced system instability?

References

- Carson & SAINT. (2017). Lessons Learned from the Equifax Breach.
- CSO Online. (2017). Change management: Equifax highlighted the vulnerability gap between disclosure and patch.
- TechCrunch. (2017). Former Equifax CEO says breach boiled down to one person not doing their job.
- Security Boulevard. (2020). 3 Years Later: The Equifax Breach.
- Hunton Andrews Kurth. (2019). Equifax Agrees to Pay Up to \$700 Million to Resolve 2017 Breach.